

密码 VS 口令

□ 密码

- 密码算法（加密算法， Hash算法， 签名算法等）
- 密钥（可以长为1024 bit, 也可以短为6个数字如123456）
 - 保存在硬件存储器
 - 保存在人脑



□ 口令

- 大家常说的“密码”实际上是“密钥”，并且是很短的密钥，人的大脑可以记住，学术界称之为“口令”—— password
- 也是密码学的范畴
- 大家天天见，天天用
- 本人的研究方向 Password Cryptography

Passwords

- ❑ Think for a minute, how many accounts do you have? More than 50? 100?
 - ❑ We don't love it, but have to live with it.
 - ❑ In the 2000s, it is widely believed that passwords will be replaced by some other techniques.
 - ❑ Since 2010, there has been wide disillusionment.
 - ❑ Today, we are faced with the same problem that confronted us twenty years ago:
 - Passwords are inherently weak, typically short strings. And thus they are guessable.
 - Passwords are prone to shoulder-surfing, key-logging and phishing attacks.
-

(Herley and Oorschot, IEEE Security&Privacy 2012)

New challenges give birth to Password Cryptography

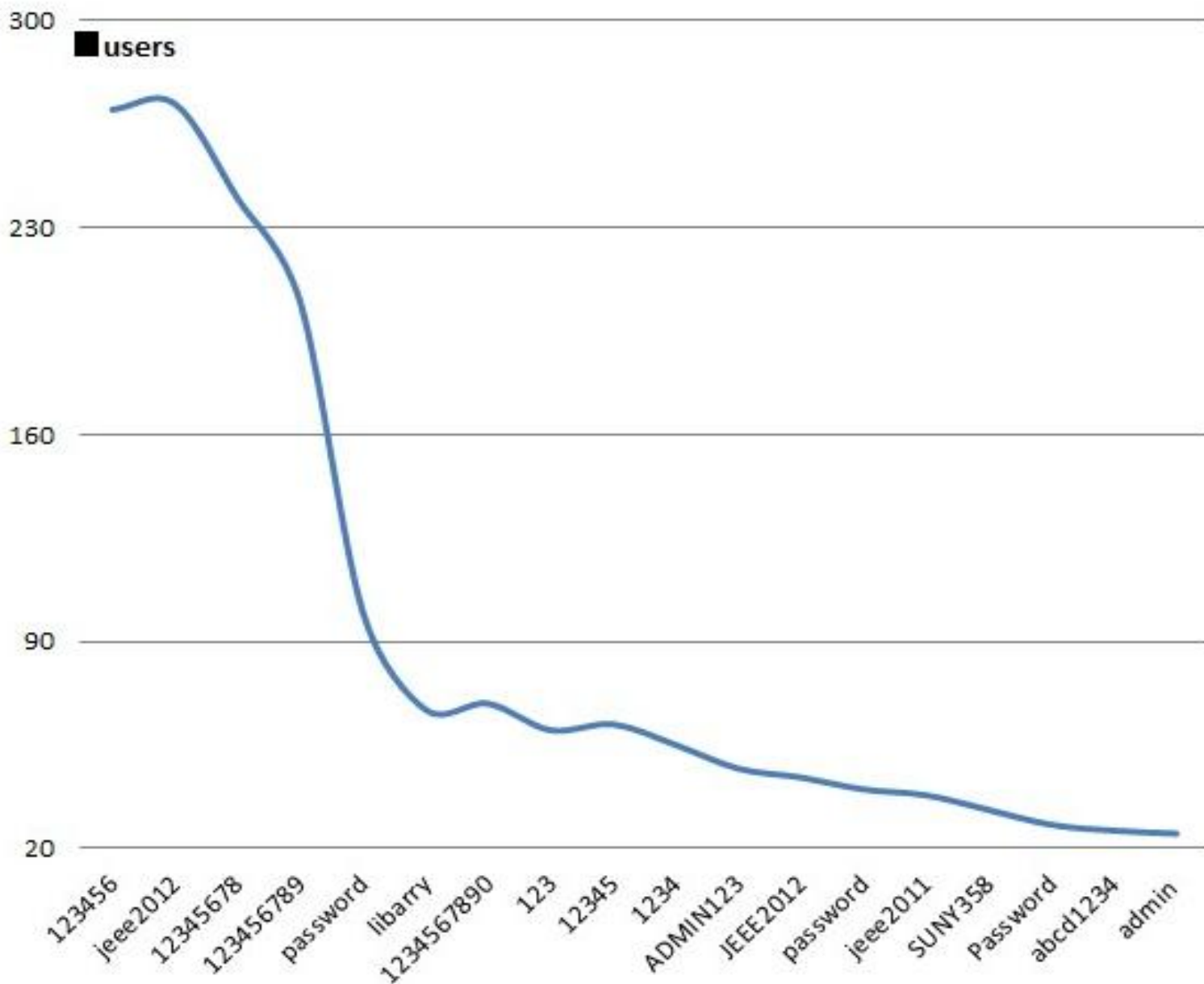
- ❑ The proliferation of malwares and viruses
- ❑ The infestation of hacker attacks, e.g., recent catastrophic password leakages
 - CSDN 600万 [口令泄露事件](#) 2011-11-20
 - 人人网 500万 口令泄露事件 2011-11-22
 - Rockyou 3200万口令泄露事件 2009-12-16
- ❑ A much deadlier problem
 - We all love to reuse passwords !
(50 accounts, only 3 distinct passwords)
- ❑ There is still no other alternatives to replace passwords, neither will there be in the near future.

Tw

□ (

□ (

Most used passwords



Enhancing the passwords

□ Two solutions

- Password + Token

123456



- Leakage-resistant password cryptography

NEW!

Deng H.教授团队在
NDSS 2012发文指出
该方法是行不通的。

 **中国建设银行**
China Construction Bank

登录密码: 

证件号码指您开通网上银行使
军官证、护照等有效证件的号
用户昵称指您在网上银行“客
设置的专用名称。 [忘记密码?](#)

如果您需要使用软键盘 ，请
图标。 [忘记密码?](#)

中国建设银行 密码输入器 使用键盘输入

附加码:

~	!	@	#	\$	%	^	&	*	(	)	_	+		退格
~	1	8	3	7	5	0	4	2	9	6	-	=	\	切换大/小写
q	w	e	r	t	y	u	i	o	p	{	}	[	]	确定
a	s	d	f	g	h	j	k	l	:	"	;	'		
z	x	c	v	b	n	m	<	>	?	,	.	/		

汇报提纲



相关知识

- 信息安全会议和期刊
- 信息安全概述
- 信息安全 VS 密码学

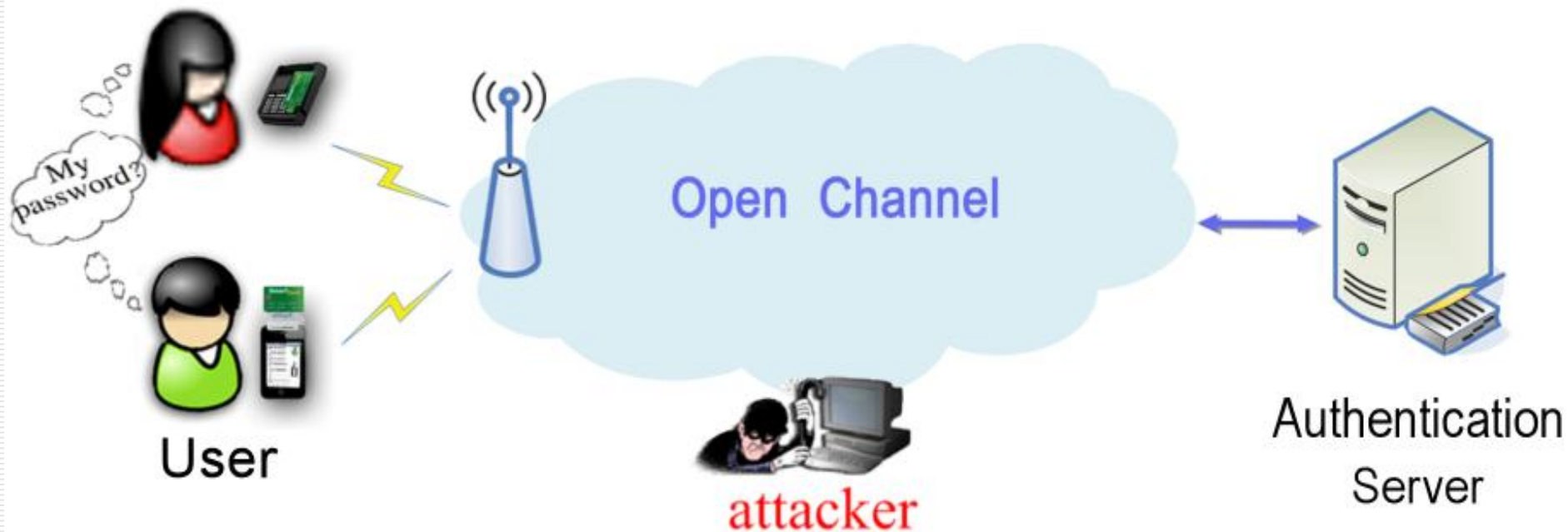


论文报告

- Introduction
 - Models
 - Attacks
-

Smart-card-based password authentication

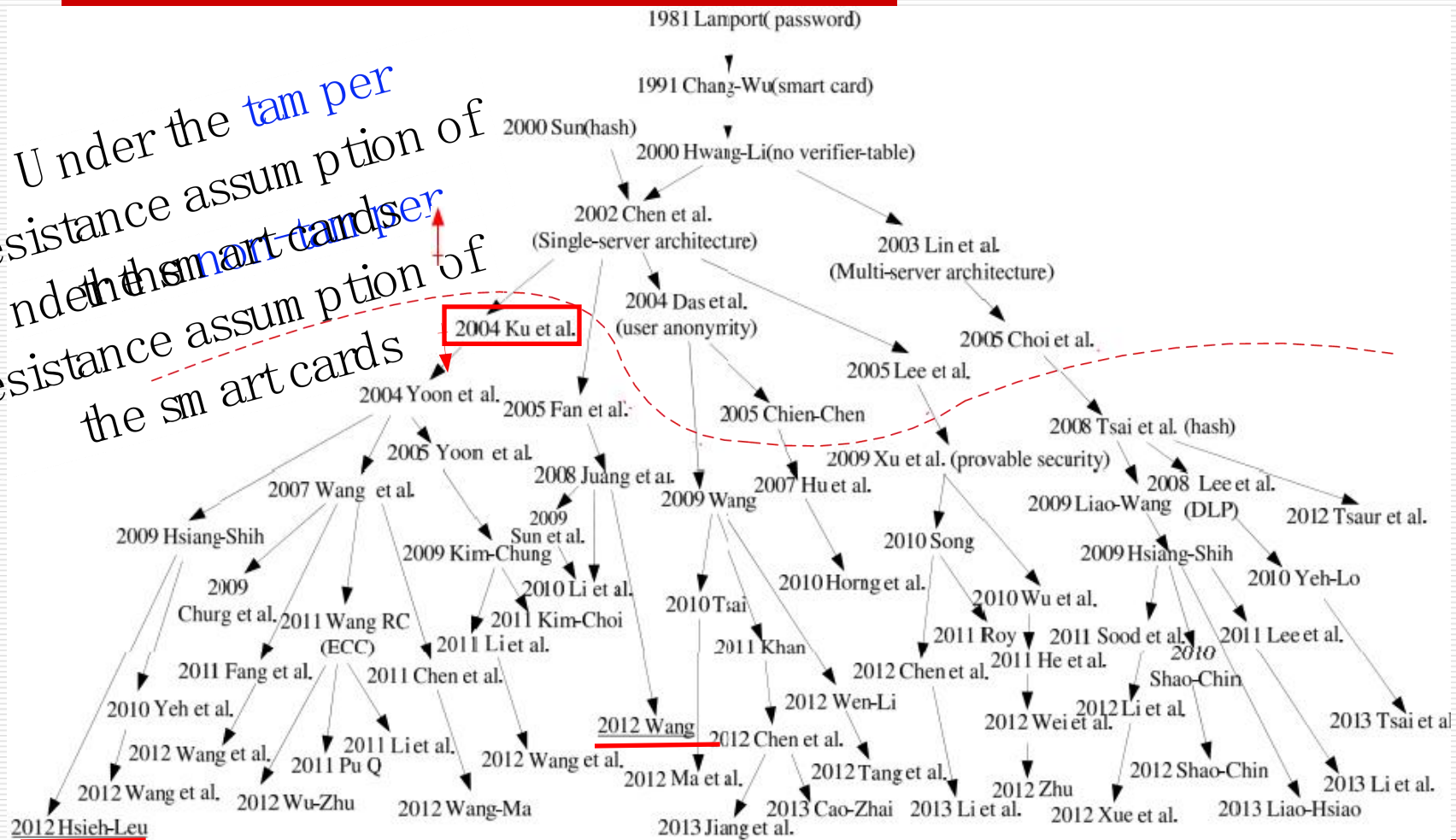
- Aim: Assuring two-factor security



Not an easy task

— A history of “break-fix-break-fix”

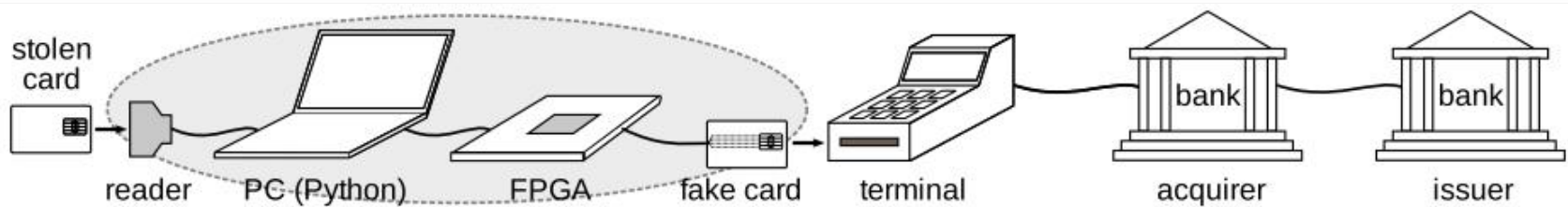
Under the tamper resistance assumption of the smart cards
Under the tamper resistance assumption of the smart cards



A real attack on EMV (Europay, MasterCard, and Visa)

BBC Newsnight

□ Ross Anderson et al., IEEE S&P 2010



Challenges



□ powerful adversary

- According to the common **Dolev-Yao adversary model**
 - (1) he can eavesdrop, replay, fabricate, intercept, block any messages over the channel
 - (2) what he cannot do is — — “crack” encrypted messages
- Due to Side-Channel attacks
 - smart cards should be assumed to be **non-tamper resistant** when in the hands of the attacker
- Breach card security without victim's aware
side-channel attacks + return card

We are the first to pay attention to this practical threat.

□ Naive users

- users tend to choose “**weak passwords**”

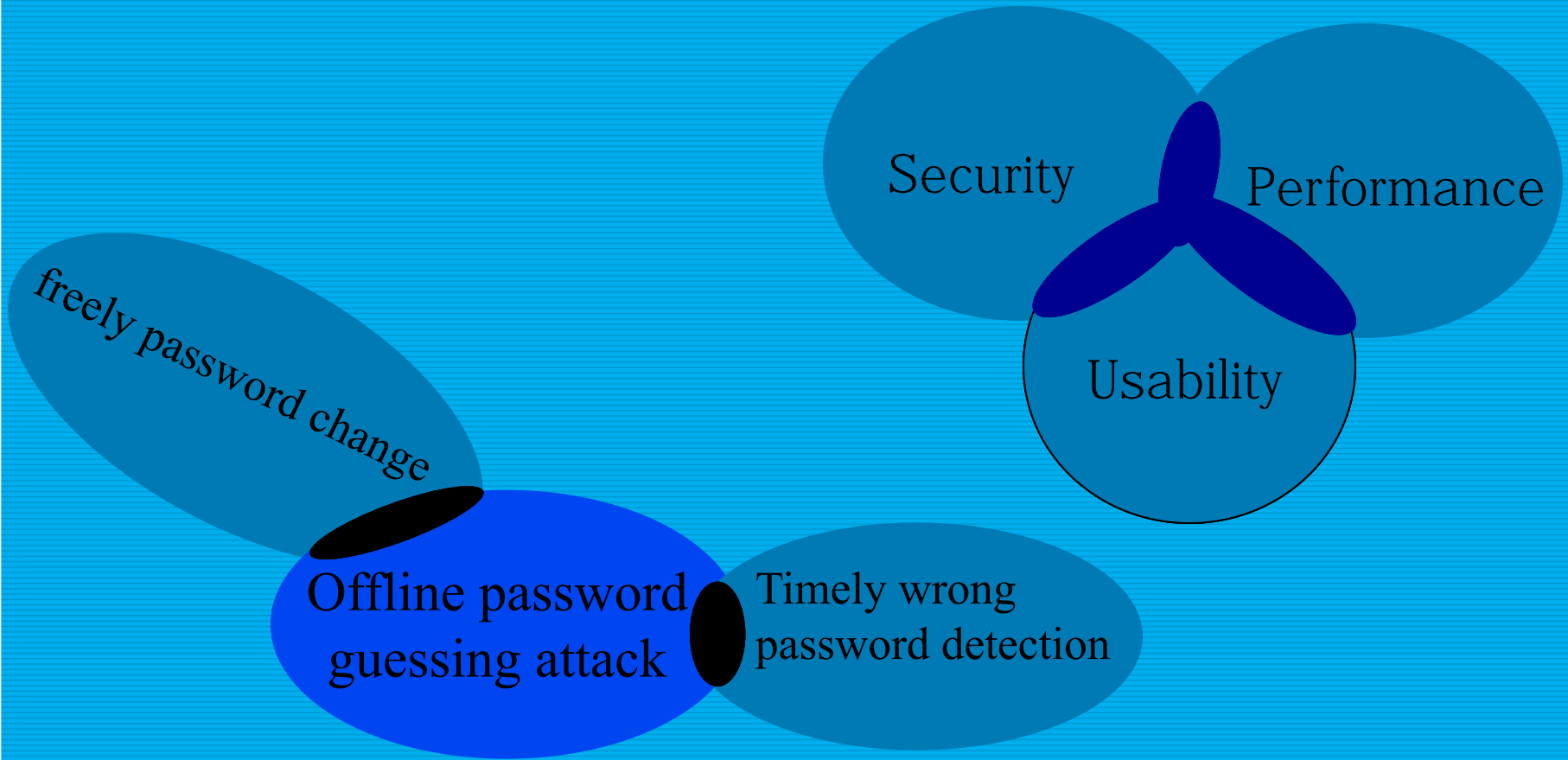


my phone number?

Challenges (continue)

- Have to reconcile the following issues
 - Security
resistance to various passive and active attacks
 - Functionalities (e.g., user friendliness)
 - Performance
-

Trade-offs and Conflicts



Contributions are threefold

- For the first time, we **explain why smart cards are preferred over USB**, even if smart cards are assumed non-tamper-proof.
- We **revisit two recent proposals** and show that, Hsieh-Leu's scheme cannot achieve two-factor security under *their own assumptions*, while Wang's PSCAV cannot achieve two-factor security under our *new attacking strategy*.
- Our attack on Wang's PSCAV is the **strongest adversary model so far**.

汇报提纲



相关知识

- 信息安全会议和期刊
- 信息安全概述
- 信息安全 VS 密码学



论文报告

- Introduction
 - Models
 - Attacks
-

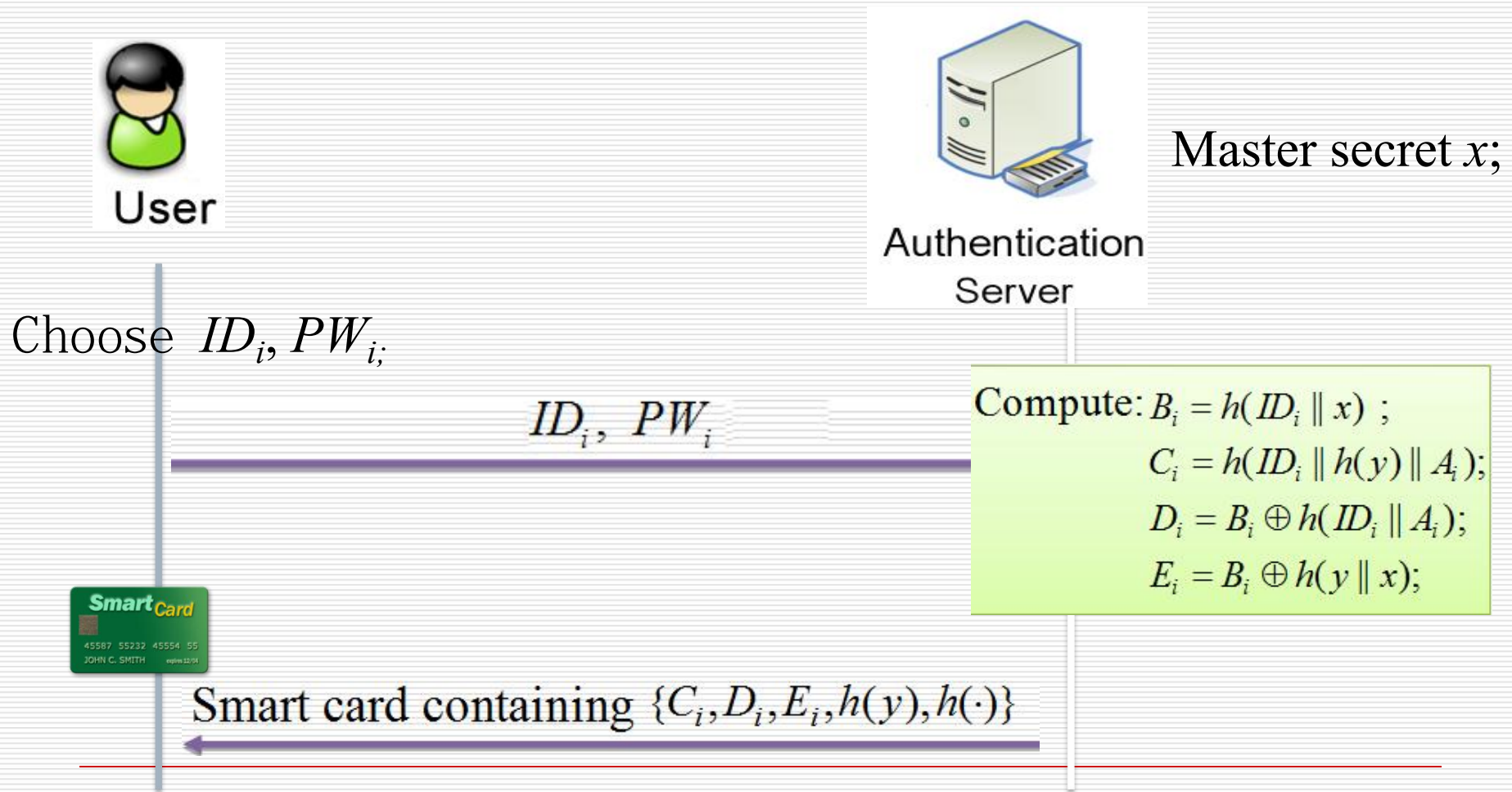
System model

□ Four phases

- Registration phase
- Login phase
- Verification phase
- Password update phase



System model—Registration phase



System model— Login and verification phase



User



Authentication
Server

Input ID_A, PW_A ;
Generate a random number $x \in_R Z_q^*$;

Compute $y_A = g^x \bmod p$;
 $c_A = (y_s)^x = g^{bx} \bmod p$;
 $f_A = W_A \oplus h(r_A \oplus PW_A)$;

$e_A = \mathcal{E}_{c_A}(f_A)$;

$DID_A = ID_A \oplus \mathcal{H}_1(y_A \| c_A)$;

$\xrightarrow{DID_A, e_A, y_A}$

Compute $c_A = y_A^b \bmod p$;

$ID_A = DID_A \oplus \mathcal{H}_1(y_A \| c_A)$;

Using ID_A to retrieve V_A, t_A from database;

Get f_A^* by decrypting e_A using c_A ;

Check $f_A^* \stackrel{?}{=} h(b \| t_A \| ID_A)$;

Generate a random number $r_s \in_R Z_q^*$;

Compute $sk = \mathcal{H}_2(c_A \| r_s \| V_A)$;

$M_s = \mathcal{H}_3(sk \| V_A)$;

$\xleftarrow{r_s, M_s}$

Compute $V_A = h(h(PW_A \oplus r_A) \oplus t_A)$;

$sk^* = \mathcal{H}_2(c_A \| r_s \| V_A)$;

Check $M_s \stackrel{?}{=} \mathcal{H}_3(sk^* \| v_A)$;

Compute $M_A = \mathcal{H}_3(ID_A \| ID_s \| sk)$;

$\xrightarrow{M_A}$

Check $M_A \stackrel{?}{=} \mathcal{H}_3(ID_A \| ID_s \| sk)$;

System model— password change phase

- A tradeoff between security and usability, mainly two approaches:
 - Through interaction with the server
 - Secure but cumbersome
 - Performed locally
 - Convenient but vulnerable

Wang et al. Security flaws in two improved remote user authentication schemes using smart cards. **Int. J. Communi. Syst.**, 2013, Doi: <http://dx.doi.org/10.1002/dac.2468> (SCI/EI)

Adversary model

for smart-card-based schemes

□ The present strongest model assumes an adversary who **can**

- (1) Have full control of the public channel
- (2) Either obtain victim's password,
or get access to user's smart card and breach it

But cannot

- (4) Breach the smart card while intercepting the victim's password by using a malicious card reader

To avoid the trivial case, the attacker is not allowed to

- (5) First compromise the user's password and then compromise the smart card
-

Two question arises

- ❑ Now that smart cards are no longer tamper proof devices, **why we do not use USB?**
- ❑ A number of papers claimed that their USB-based schemes can enjoy all the advantages of smart-card-based schemes, **why?**

We investigate these two questions for the first time.

Adversary model

for USB-based schemes

- The present widely accepted model assumes an adversary who **can**
- (1) Have full control of the public channel
 - (2) Obtain victim's password
 - (3) Compromise the victim's USB device through malware within a short time period
 - (4) Extract the sensitive information on the USB while intercepting the victim's password by using malwares

In contrast, the **attacker cannot**

- (5) Intercept the victim's password by using malwares while compromising the smart card, because
- compromising the smart card is a special instruction

综合(4)(5), USB-based Schemes is not suitable for use in un-trusted terminals.

The answers to these two questions

- Now that smart cards are no longer tamper proof devices, **who we do not use USB?**

Answer: USB-based schemes are unfit for application in un-trusted terminals.

- A number of papers claimed that their USB-based schemes can enjoy all the advantages of smart-card-based schemes, **really?**

Answer: Of course, not.

汇报提纲



相关知识

- 信息安全会议和期刊
- 信息安全概述
- 信息安全 VS 密码学



论文报告

- Introduction
 - Adversary Models
 - Attacks
-

Review of Hsieh-Leu's scheme

- Hsieh-Leu's scheme
 - the registration phase
 - the login phase
 - the verification phase
 - the password update phase

Hsieh, W., Leu, J.: Exploiting hash functions to intensify the remote user authentication scheme. *Computers & Security* 31(6), 791–798 (2012)

CCF B类期刊

Review of Hsieh-Leu's scheme (1/3)

— User registration



User

Choose ID_i, PW_i ;
Choose a random b ;
Compute $h(b \oplus PW_i)$;

$ID_i, h(PW_i), h(b \oplus PW_i)$



Authentication
Server

Master secret x ;

Create an entry for U_i , set $n=0$;
Compute $EID = h(h(ID_i) || n)$;

$P = h(EID || x)$;

$R = P \oplus h(b \oplus PW_i)$;

$V = h(h(PW_i) \oplus h(x))$;

Store $\{ID_i, V, n\}$ in database;

A smart card containing $\{R, h(\cdot)\}$



Write b into smart card

Review of Hsieh-Leu's scheme(2/3)

— Login and verification phase



Input ID_A, PW_A ;
 Generate a random number $x \in_R Z_q^*$;
 Compute $y_A = g^x \bmod p$;
 $c_A = (y_s)^x = g^{bx} \bmod p$;
 $f_A = W_A \oplus h(r_A \oplus PW_A)$;
 $e_A = \mathcal{E}_{c_A}(f_A)$;
 $DID_A = ID_A \oplus \mathcal{H}_1(y_A \| c_A)$;
 $\xrightarrow{DID_A, e_A, y_A}$
 Compute $V_A = h(h(PW_A \oplus r_A) \oplus t_A)$;
 $sk^* = \mathcal{H}_2(c_A \| r_s \| V_A)$;
 Check $M_s \stackrel{?}{=} \mathcal{H}_3(sk^* \| v_A)$;
 Compute $M_A = \mathcal{H}_3(ID_A \| ID_s \| sk)$;
 $\xrightarrow{M_A}$

Compute $c_A = y_A^b \bmod p$;
 $ID_A = DID_A \oplus \mathcal{H}_1(y_A \| c_A)$;
 Using ID_A to retrieve V_A, t_A from database;
 Get f_A^* by decrypting e_A using c_A ;
 Check $f_A^* \stackrel{?}{=} h(b \| t_A \| ID_A)$;
 Generate a random number $r_s \in_R Z_q^*$;
 Compute $sk = \mathcal{H}_2(c_A \| r_s \| V_A)$;
 $M_s = \mathcal{H}_3(sk \| V_A)$;
 Check $M_A \stackrel{?}{=} \mathcal{H}_3(ID_A \| ID_s \| sk)$

Review of Hsieh-Leu's scheme (4/4)

—— Password Change phase

- Support local password update;
 - We only focus on the login and verification phase, and omit this phase.
-

Two vulnerabilities

- Offline password guessing attack
 - the most damaging threat to a password protocol

 - User anonymity breach
 - Li, X., Xiong, Y., Ma, J., Wang, W.: An efficient and secure **dynamic identity based** authentication protocol for multi-server architecture using smart cards. Journal of Network and Computer Applications 35(2), 763–769 (2012)
 - Which means the essential goal can not be achieved
-

Security Flaws (1/2)

—Offline password guessing attack

$$\mathcal{O}(|\mathcal{D}| * (5T_H + 6T_X))$$

password



obtains $\{D_i, E_i, b, h(y), h(\cdot)\}$ in U_i 's smart card
intercepted $\{F_i, CID_i, G_i\}$

1. Extracts $h(y)$ from her own smart card;
2. Computes $N_{i1} = F_i \oplus h(y)$, where F_i is intercepted from the public channel;
3. Computes $E_i = P_{ij} \oplus h(h(y) \parallel N_{i1} \parallel SID_j)$, where P_{ij} and SID_j are intercepted from the public channel.
4. Computes $h(y \parallel x) = E_m \oplus B_m = E_m \oplus D_m \oplus h(ID_m \parallel A_m) = E_m \oplus D_m \oplus h(ID_m \parallel h(b \parallel P_m))$, where E_m, D_m and b are revealed from U_m 's own smart card;
5. Computes $B_i = E_i \oplus h(y \parallel x)$, where E_i is revealed from U_i 's smart card;
6. Computes $A_i = CID_i \oplus h(B_i \parallel F_i \parallel N_{i1})$;
7. Guesses the value of P_i to be P_i^* from the password space $\mathcal{D}$.
8. Computes $A_i^* = h(b \parallel P_i^*)$, where b is revealed from U_i 's smart card.
9. Verifies the correctness of P_i^* by checking if A_i^* equals to A_i .
10. Repeats Steps 7, 8 and 9 until the correct value of P_i is found.

Experiments

- Common Laptops
- Linux 2.6.10

Table 2. Computation evaluation of related operations on common Laptop PCs

Experimental platform (common PCs)	Exponentiation T_E ($ n =1024$)	Symmetric encryption T_S (AES-128)	Hash operation T_H (SHA-1)	Other lightweight operations(e.g., XOR)
Intel T5870 2.00 GHz	10.526 ms	2.012 μ s	2.437 μ s	0.011 μ s
Intel i5750 2.66 GHz	8.214 ms	1.617 μ s	1.980 μ s	0.009 μ s
Pentium IV 3.06 GHz	7.309 ms	1.425 μ s	1.526 μ s	0.008 μ s

Security Flaws (2/2)

— User anonymity breach attack



1. U_m extracts $h(y)$ from her own smart card;
2. U_m and S_j collude to compute $N_{i1} = F_i \oplus h(y)$, where F_i is intercepted from the public channel;
3. U_m and S_j collude to compute $E_i = P_{ij} \oplus h(h(y) \parallel N_{i1} \parallel SID_j)$, where P_{ij} and SID_j are intercepted from the public channel.

E_i is kept static in all of U_i 's login requests, and thus can be exploited to trace user activity.

Lessons learned from the cryptanalysis

□ Two further observations

- Only symmetric-key primitives (such as Hash, symmetric encryption, MAC) are intrinsically inadequate to withstand offline password guessing attack.

(We managed to prove it in the following work:

Security flaws in the design of remote user authentication schemes using smart cards. *Int. J. Commun. Syst.* submitted on Sep 7, 2012. Last week, it was accepted and made

- In the major attacks are

By following our two observations, more than 50% this type of schemes can be easily found problematic.

— Our new work. On the anonymity of two factor authentication schemes

Attacking Wang's PSCAV

- Our attack on Hsieh-Leu's scheme can be generalized as follows:

- (1) Intercept some transcripts during the previous login session(s);
- (2) Obtain the security parameters stored in the victim's smart card;
- (3) Repeatedly guess the victim's password via an offline automated program.

- The following attack on Wang's PSCAV using a new strategy:

- (1) Obtain the security parameters stored in the victim's smart card
 - (2) Return the exposed card to the victim without detection;
 - (3) Impersonate the server to interact with the victim (and intercept the exchanged messages during this course);
 - (4) Repeatedly guess the victim's password via an offline automated program.
-

Review of Wang's PSCAV

□ Wang's PSCAV

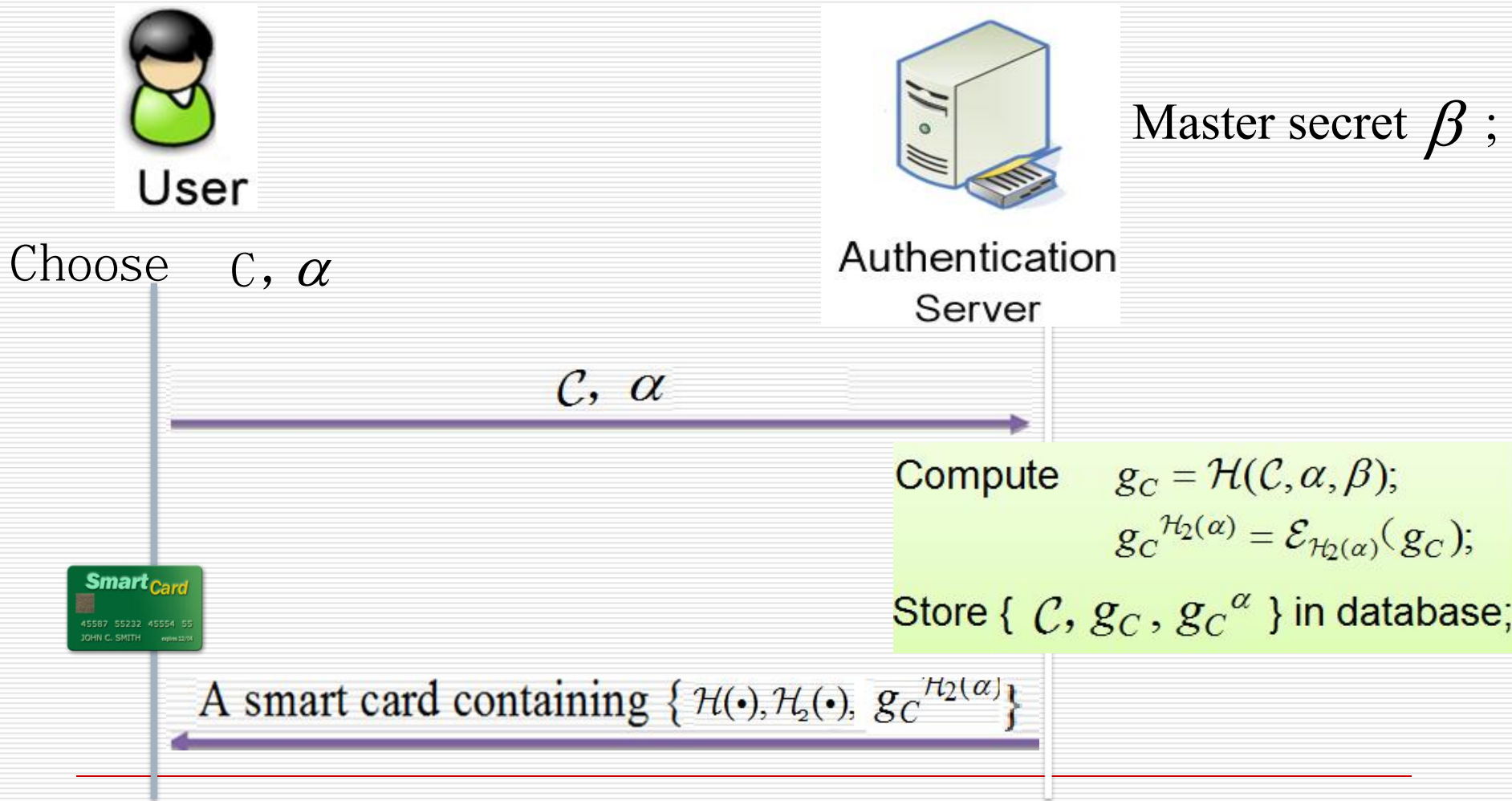
- the registration phase
- the login and verification phase

Wang, Y.G.: Password protected smart card and memory stick authentication against off-line dictionary attacks. In: Gritzalis, D., Furnell, S., Theoharidou, M. (eds.) SEC 2012, IFIP AICT, vol. 376, pp. 489–500. Springer (2012)

CCF C类会议

Review of Wang's scheme (1/2)

— User registration



Review of Wang's scheme(2/2)

— Login and verification phase



User



Authentication Server

Knows $(\mathcal{C}, \alpha)$

Knows $\beta, (\mathcal{C}, g_{\mathcal{C}}, g_{\mathcal{C}}^{\alpha})$

Inputs $\mathcal{C}, \alpha$, smart card selects random x ;

smart card computes $g_{\mathcal{C}} = \mathcal{D}_{\mathcal{H}_2(\alpha)}(g_{\mathcal{C}}^{\mathcal{H}_2(\alpha)})$;

Computes $u = \mathcal{H}(\mathcal{C}, \mathcal{S}, R_A, R_B)$

$$sk = g_{\mathcal{C}}^{y(x+u)}$$

$$C_{\mathcal{C}} = \mathcal{H}(sk, \mathcal{C}, \mathcal{S}, R_A, R_B, 1)$$

Checks the validity of $C_{\mathcal{S}}$;

Selects random y ;

Checks the validity of $C_{\mathcal{C}}$;

Computes $u = \mathcal{H}(\mathcal{C}, \mathcal{S}, R_A, R_B)$

$$sk = (R_A)^y \cdot g_{\mathcal{C}}^{y^{u\alpha}}$$

$$C_{\mathcal{S}} = \mathcal{H}(sk, \mathcal{S}, \mathcal{C}, R_B, R_A, 2)$$

Offline password guessing attack on Wang's scheme (1)

□ The attacking strategy:

- (1) Obtain the security data stored in the victim's smart card;
- (2) Return the exposed card to the victim without detection;
- (3) Impersonate the server to interact with the victim;
- (4) Repeatedly guess the victim's password via an offline automated program.

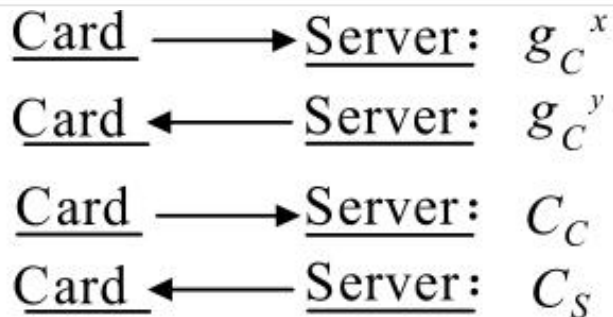


Fig.1 Message flows of PSCAV

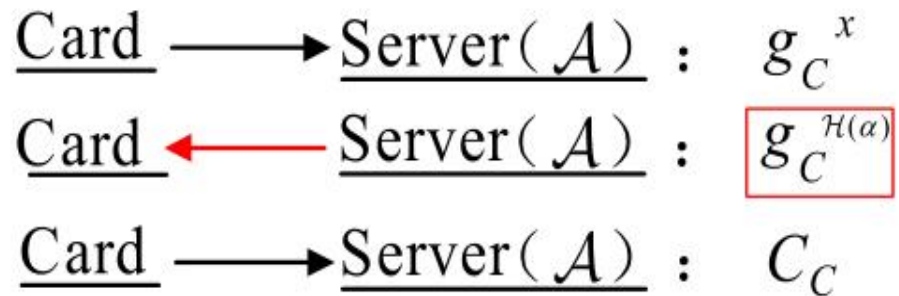
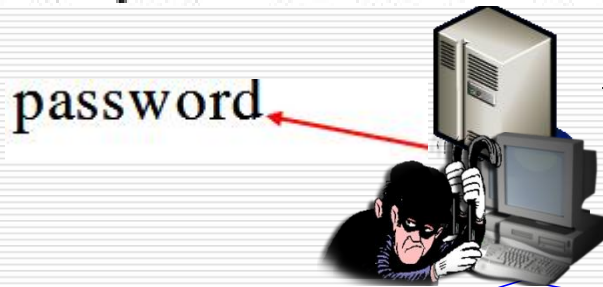


Fig.2 Our attack

Offline password guessing attack on Wang's scheme (2)

$$\mathcal{O}(|\mathcal{D}_{pw}| * (3T_E + T_S + 3T_H))$$



password

- Obtains $g_C^{\mathcal{H}_2(\alpha)}$ in C 's smart card
- Sends back the exposed card to the victim C

- step 1. On intercepting $R_A = g_C^x$ from client C , $\mathcal{M}$ blocks it and sends $R_B = g_C^{\mathcal{H}_2(\alpha)}$ to the client on behalf of the server, where $g_C^{\mathcal{H}_2(\alpha)}$ is extracted from C 's card;
- step 2. On receiving the response C_C , $\mathcal{M}$ computes $u = \mathcal{H}(\mathcal{C}, \mathcal{S}, R_A, R_B)$.
- step 3. Guesses the value of password α to be α^* from dictionary $\mathcal{D}_{pw}$.
- step 4. Computes $g_C^* = \mathcal{D}_{\mathcal{H}_2(\alpha^*)}(g_C^{\mathcal{H}_2(\alpha)})$;
- step 5. Computes $sk^* = g_C^{x\mathcal{H}_2(\alpha^*)} \cdot (g_C^*)^{u\alpha^*\mathcal{H}_2(\alpha^*)}$
 $= (R_A)^{\mathcal{H}_2(\alpha^*)} \cdot (g_C^*)^{u \cdot \alpha^* \cdot \mathcal{H}_2(\alpha^*)}$;
- step 6. $\mathcal{M}$ computes $C_C^* = H(sk^*, \mathcal{C}, \mathcal{S}, R_A, R_B, 1)$;
- step 7. Verifies the correctness of α^* by checking if the computed C_C^* is equal to the received C_C ;
- step 8. Repeats the above Steps 3-8 until the correct value of α is found.

Experiments

- Common Laptops
- Linux 2.6.10
- For $|\mathcal{D}_{pw}| \leq 10^6$, it only takes **1~2 hours** to recover the expected password!

Table 2. Computation evaluation of related operations on common Laptop PCs

Experimental Platform (common PCs)	Exponentiation T_E ($ n =1024$)	Symmetric encryption T_S (AES-128)	Hash operation T_H (SHA-1)	Other lightweight operations(e.g.,XOR)
Intel T5870 2.00 GHz	10.526 ms	2.012 μ s	2.437 μ s	0.011 μ s
Intel E5500 2.80 GHz	7.716 ms	0.530 μ s	0.756 μ s	0.009 μ s
Intel i5-3210 2.50 GHz	4.390 ms	0.415 μ s	1.132 μ s	0.008 μ s

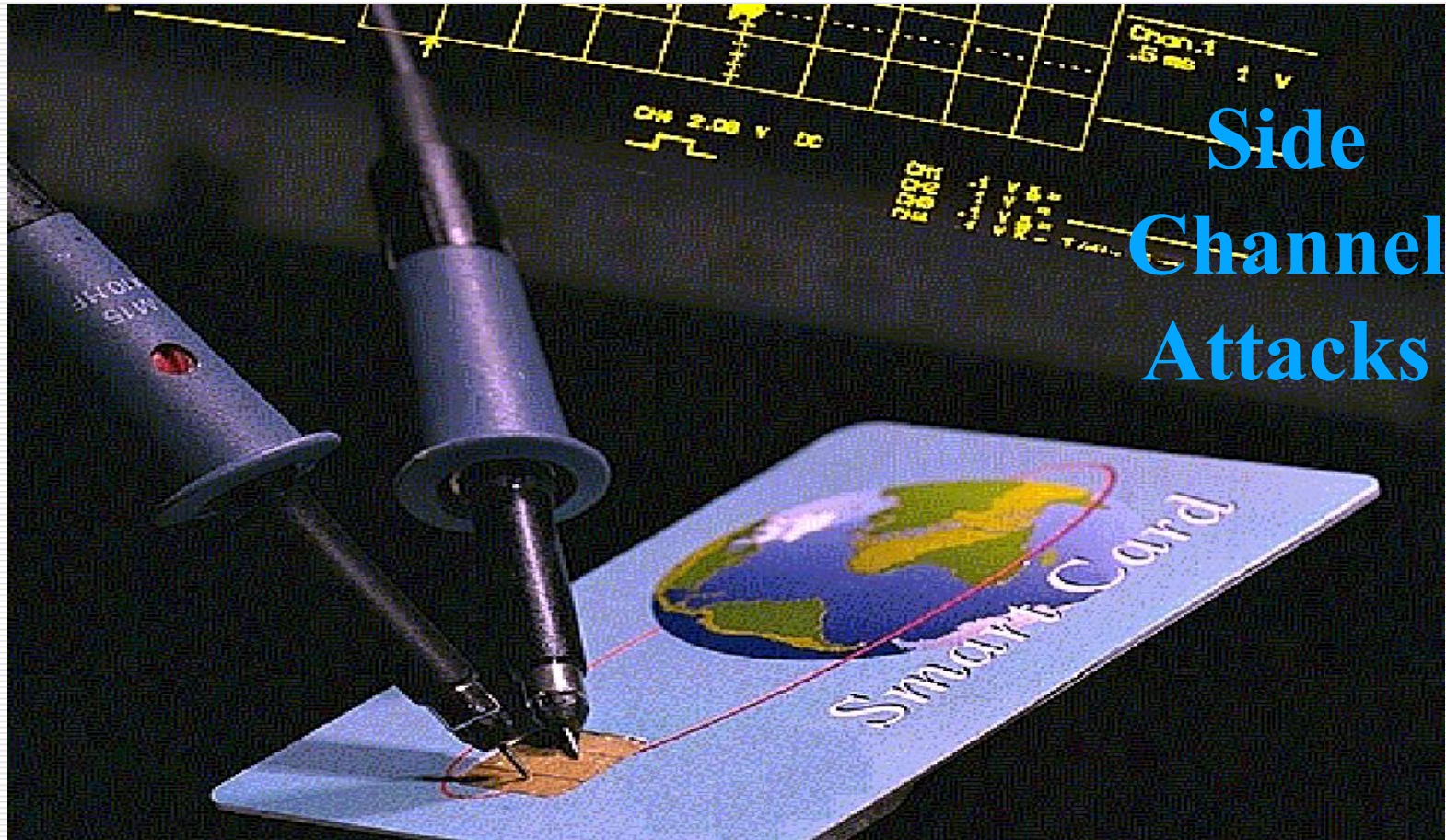
Conclusion

- ❑ We have explained why smart cards are preferred to USB-alike devices in two-factor schemes.
 - ❑ Two practical attacks are demonstrated on Hsieh-Leu's scheme and Wang's scheme, respectively.
 - ❑ A new attacking strategy is highlighted:
 - There is potential that the attacker may return the exposed card to the victim!
 - ❑ Remarkably, our new attacking strategy has already given rise to the strongest adversary model so far — Type III-r.
-

THANK YOU

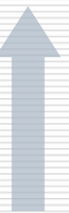
THANK YOU & QUESTIONS

Side-Channel Attack



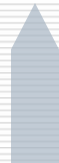
Various attacks

- ☐ Offline password guessing attack
- ☐ Smart card loss attack
- ☐ Stolen verifier attack
- ☐ User impersonation attack
- ☐ Server masquerading attack
- ☐ Replay attack
- ☐ Parallel session attack
- ☐ Denial of service attack
- ☐ Password disclosure to server (Insider attack)
- ☐ Forward secrecy
- ☐ Key compromise impersonation attack
- ☐ Unknown key share attack
- ☐ ...



Functionalities

- ☐ key agreement
- ☐ mutual authentication
- ☐ local password change
- ☐ user anonymity (initiator un-traceability)
- ☐ no verifier table
- ☐ support weak password
- ☐ non-tamper resistant smart cards
- ☐ repairability



Performance

- ❑ Computation complexity (a big hill)

cryptographic operations are often computation-intensive, like modular exponentiation, modulo inversion, pairing ...

- ❑ Storage cost (not a big problem)

- ❑ Communication overhead (not a big problem)

